



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



AvosLocker MAR

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-13
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | AvosLocker MAR - Malware Analysis Report

Published: 2026-06-13 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

AvosLocker / SonicBoom Ransomware Sample Analysis

1. Executive Summary

This report assesses a 32-bit Windows PE sample with SHA256 ``ffd933ad53f22a0f10cceb4986087258f72dffdd36999b7014c6b37c157ee45f``. Static analysis provides high-confidence identification of the sample as AvosLocker ransomware, specifically a SonicBoom build variant. The strongest evidence is the combination of family-identifying strings (``AvosLocker``, ``Build: SonicBoom``), a matching ransom note template, the embedded onion payment portal ``avosjon4pfb3y7ew3jdwz6ofw7lljcxlbk7hcxxmnlh5kvf2akcqjad.onion``, the ``.avos2`` extension, and CLI options/anti-recovery commands consistent with publicly documented AvosLocker tradecraft.

The sample imports Windows APIs associated with filesystem traversal, privilege adjustment, restart-manager-assisted file unlocking, SMB resource enumeration, and cryptographic operations. FLOSS and radare2 output also expose pre-encryption host preparation commands including deletion of shadow copies, boot-recovery suppression, and event-log clearing. Reverse-engineering signals further show embedded Crypto++/Rijndael and SHA-256 routines, which align with public reporting that AvosLocker uses AES-256 for file encryption and RSA to protect per-file or per-session material.

A controlled TRASHcan VirtualBox detonation completed successfully, but it did not yield a trustworthy malicious process tree or destructive runtime trace. The sandbox recorded no dropped files, no Sysmon process events, no registry/file-create events attributable to the sample, and no Suricata alerts; the observed network activity was dominated by baseline Microsoft/Edge traffic. Accordingly, the family identification is high-confidence, but claims about the exact live execution path in this run remain medium-confidence.

From a defensive standpoint, the sample should be treated as a high-severity ransomware indicator and a likely broader compromise lead rather than a standalone nuisance binary. Even though the local execution run was low-signal, the sample's embedded behavior strongly supports hunting for anti-recovery commands, mass-encryption follow-on activity, ransom-note creation, suspicious SMB enumeration, and file-renaming into the ``.avos2`` extension.

2. Sample Metadata

Field	Value
Family	AvosLocker / SonicBoom
Malware Type	Ransomware
Platform	Windows x86
Primary Sample SHA256	<code>`ffd933ad53f22a0f10cceb4986087258f72dffdd36999b7014c6b37c157ee45f`</code>
Additional Hashes	SHA1 <code>`40207f83b601cd60905c1f807ac0889c80dfe33f`</code> ; MD5 <code>`e27b5291c8fb2dfdeb7f16bb6851df5e`</code>
File Type / Format	PE32 executable (console), Intel 80386, 5 sections
Sample Size	826,880 bytes
Compile Timestamp	2021-11-06 03:19:15 UTC (PE header; potentially spoofable but plausible)
Analyst Confidence	High for family identification; Medium for runtime specifics in this detonation
Primary Objective	Data encryption, recovery inhibition, and likely double-extortion enablement

3. Source Review & Confidence

Source	Contribution	Confidence
Local static analysis (`file`, `exiftool`, `rabin2`, `objdump`, `strings`, `FLOSS`, `radare2`)	Core family identification and capability evidence	High
Local sandbox run (`TRASHcan` run `2026-06-13_060903_ffd933ad53f2`)	Negative runtime evidence and environmental context	Medium
MITRE ATT&CK S1053	External corroboration for family identity, extensions, and platform scope	High
CISA advisory AA23-284A and Zscaler retrospective	External corroboration for TTPs, CLI semantics, and campaign behavior	Medium

Observed facts in this report are limited to the extracted binary, its decoded strings/imports, and the local sandbox artifacts. High-confidence assessment ties those facts to AvosLocker via exact-family identifiers. Lower-confidence assessment includes runtime conclusions that could have been constrained by lab telemetry gaps or execution preconditions not met in the guest.

4. Initial Triage and Delivery Assessment

The submitted artefact was a password-protected 7z archive containing one PE32 console executable. The archive was extracted in the task workspace and the resulting binary was triaged directly. No companion loader, document lure, or multi-stage dropper was observed in the archive contents available for this task.

Variant / Artefact	Delivery Role	Notes
`ffd933ad53f22a0f10cceb4986087258f72df` `fdd36999b7014c6b37c157ee45f.7z`	Container	Password-protected submission to portal intake
`ffd933ad53f22a0f10cceb4986087258f72df` `fdd36999b7014c6b37c157ee45f`	Primary payload	PE32 Windows ransomware sample

5.1 File and Build Characteristics

The sample is an unpacked PE32 Windows console binary with five conventional sections (`.text`, `.rdata`, `.data`, `.rsrc`, `.reloc`) and no export table. `rabin2 -I` and `objdump -x` show `DYNAMIC\_BASE`, `NX\_COMPAT`, and `TERMINAL\_SERVICE\_AWARE`, with image base `0x00400000` and entry point `0x000337fd`. Strings and C++ symbol leakage indicate the binary was built with Crypto++ components rather than heavily stripped shellcode-style tooling.

Static Signal	Evidence	Analyst Value
Family self-identification	FLOSS recovered `AvosLocker` and `Build: SonicBoom`	Strong family attribution anchor
Ransom-note infrastructure	Embedded onion URL `avosjon4pfh3y7ew3jdwz6ofw7lljcxlbk7hc` `xxmnx1h5kvf2akcqjad.onion`	High-confidence victim-contact IOC
File extension behavior	FLOSS recovered `avos2` and a long extension skip-list containing `avos`, `avoslinux`, and `avos2`	Indicates encryption/rename workflow and exclusion logic
Anti-recovery commands	Strings include `vssadmin.exe Delete Shadows /All /Quiet`, `wmic shadowcopy delete /nointeractive`, `bcdedit` recovery	Supports destructive impact and recovery-inhibition assessment

	suppression, and event-log clearing	
Crypto library artefacts	radare2 identified Crypto++ `Rijndael`, `SHA256`, `RandomPool`, and related classes	Supports AES/RSA encryption assessment

5.2 Strings, Imports, and Embedded Artefacts

High-value imports include `CryptImportKey`, `CryptEncrypt`, `CryptAcquireContextA`, `CryptGenRandom`, `CryptImportPublicKeyInfo`, `OpenProcessToken`, `LookupPrivilegeValueA`, `AdjustTokenPrivileges`, `SetNamedSecurityInfoW`, `RmStartSession`, `RmRegisterResources`, `FindFirstVolumeW`, `FindNextVolumeW`, `WNetOpenEnumA`, `WNetEnumResourceA`, and `WNetAddConnection2A`. Together these support a workflow of privilege adjustment, file enumeration, locked-file handling, remote-share discovery, and encryption.

Recovered strings show the ransomware can:

- clear backups and inhibit recovery,
- enumerate SMB resources,
- optionally disable logical-drive enumeration,
- ignore mutex protection (`nomutex`),
- hide its console window,
- set a maximum thread count (`threads`), and
- write a ransom note referring victims to the AvosLocker onion service.

A lower-confidence static domain `omk.oro` was also present in decoded strings, but it lacked corroborating context and is therefore treated as an unvalidated IOC rather than a stable family indicator.

5.3 Static Configuration Clues

The following configuration-like clues were recovered prior to execution:

- build marker: `SonicBoom`
- ransom note branding: `AvosLocker`
- victim payment portal: `avosjon4pjh3y7ew3jdwz6ofw7lljcxlbk7hcxxmnxh5kvf2akcqjad.onion`
- encryption extension reference: `.avos2`
- execution controls: `threads`, `hide`, `enablesmb`, `disabledrives`, `nomutex`
- likely target/process disruption list including office, mail, database, and browser-related process names

6.1 Reverse-Engineering Method

Code-oriented validation used `rabin2`, `objdump`, `FLOSS`, and `radare2` (`aaa`, string extraction, and function enumeration). `capa` was attempted twice with 300-second and 600-second budgets respectively and timed out both times, so capability claims below are grounded in decoded strings, imports, and leaked Crypto++ symbols rather than capa rule output.

6.2 Functions and Logic of Interest

The binary is not richly symbolized, but it leaks enough structural information to support several logic assessments.

Function / Routine	Evidence	Why It Matters
Crypto material handling	Imports `CryptImportPublicKeyInfo`, `CryptImportKey`, `CryptEncrypt`; strings mention `Client RSA key was GENERATED` and `Importing public key for encryption`	Supports hybrid encryption workflow consistent with ransomware operations

AES/SHA implementation	radare2 enumerated `CryptoPP::Rijndael::Enc`, `CryptoPP::SHA256`, `RandomPool`, `AutoSeededRandomPool`	Indicates native cryptographic implementation rather than simple wrapper logic
Locked-file / process disruption handling	Imports `RmStartSession`, `RmRegisterResources`, `RmGetList`, `RmEndSession`; strings include long process/service target lists	Consistent with terminating or bypassing file locks prior to encryption
Volume and share enumeration	Imports `FindFirstVolumeW`, `FindNextVolumeW`, `GetDriveTypeW`, `GetVolumePathNamesForVolumeNameW`, `WNetOpenEnumA`, `WNetEnumResourceA`, `WNetAddConnection2A`	Supports local-drive and SMB-target coverage
Recovery inhibition	Embedded commands for `vssadmin`, `wmic shadowcopy`, `bcdedit`, and event- log clearing	Strong signal for impact staging and anti- recovery behavior

6.3 Anti-Analysis, Evasion, and Obfuscation

The sample uses decoded/runtime strings rather than leaving all operator-facing content plainly visible, and it includes `CreateMutexA` plus a `nomutex` option to alter single-instance behavior. Importing `IsDebuggerPresent` also suggests at least minimal anti-analysis awareness. However, the binary does not appear heavily packed, and it leaves clear family-identifying strings that materially simplify analyst attribution.

7.1 Execution Overview

A TRASHcan local detonation ran the archive for 180 seconds in the `win-malware-lab` guest restored from snapshot `clean-guestadditions-sysmon`. The helper completed successfully and produced `analysis.md`, `summary.json`, `behavior\_summary.json`, IOC exports, and detection sidecars in run directory `/home/lost0x01/obsidian/05 Security Research/Malware Analysis/Runs/2026-06-13\_060903\_ffd933ad53f2`.

7.2 Filesystem, Registry, Service, and Task Changes

The run did not surface a trustworthy malicious process tree or host-modification chain. `behavior\_summary.json` reported:

- no dropped files,
- no scheduled tasks,
- no services,
- no Sysmon process events,
- no Sysmon file-create events,
- no Sysmon registry events.

The only persistence-style finding was a OneDrive autorun key already consistent with normal guest baseline activity and not attributed here to the sample.

7.3 Network and Command-and-Control Behaviour

The sandbox recorded DNS, TLS SNI, and HTTP traffic, but the resulting values were dominated by benign Microsoft/Edge infrastructure such as `www.bing.com`, `go.microsoft.com`, `edge.microsoft.com`, `settings-win.data.microsoft.com`, `ctldl.windowsupdate.com`, and `www.msftconnecttest.com`. No fake HTTP/HTTPS hits were observed, no Suricata alerts fired, and the generated report itself stated `HTTP Requests: None observed` despite counting 94 requests, reinforcing the conclusion that these were baseline guest artefacts rather than ransomware networking.

7.4 Observed Capability Summary

Capability	Supporting Dynamic Evidence
------------	-----------------------------

Successful guest execution attempt	Guest-control runner finished cleanly and produced a full artefact set
Malicious destructive activity in this run	Not directly observed
Live C2 / exfiltration in this run	Not directly observed
Anti-recovery / encryption impact in this run	Not directly observed despite strong static support

8. Process Tree and Execution Chain

The local run did not collect a usable guest process tree. This is an evidence gap, not evidence of benignness. Based on static analysis, the expected execution chain would likely involve the sample launching directly as a console PE, performing environment and privilege checks, enumerating local and optionally remote resources, attempting file-unlock / recovery-inhibition commands, and then executing threaded encryption plus ransom-note deployment.

Step	Parent Process	Child / Action	Why It Matters
1	Unknown in this run	Sample launch	Guest-control execution completed but process lineage was not preserved
2	Sample	Volume/share enumeration and privilege adjustment	Supported by imports and CLI flags
3	Sample	Shadow-copy / recovery suppression commands	Supported by recovered command strings
4	Sample	File encryption and note deployment	Supported by note text, `.avos2`, and cryptographic artefacts

9. Persistence and System Modification

No trustworthy persistence or durable host modification attributable to the sample was observed in the local run. Static evidence supports system-impact behavior, but not long-term persistence as a primary objective.

Modification Type	Artefact	Evidence	Confidence
Recovery inhibition	`vssadmin`, `wmic shadowcopy`, `bcdedit`, event-log clearing commands	Embedded strings	High
Long-term persistence	None validated in this task	No corroborating dynamic evidence	Low

10. Network and Infrastructure Analysis

The binary contains a stable victim-contact onion service and one unvalidated static domain string. No meaningful live network infrastructure attributable to the sample was validated in detonation.

IOC / Infrastructure	Type	Role	Stability / Confidence
`avosjon4pfh3y7ew3jdwz6ofw7lljcxlbk7hcxxmnx1h5kvf2akcq`	Onion URL / domain	Victim payment / negotiation	High

jad.onion`		portal	
`omk.oro`	Domain	Unclear static artefact	Low
Microsoft / Edge endpoints seen in detonation	Domain / URL	Guest baseline noise	Excluded from malware IOC set

11. Indicators of Compromise

The complete machine-readable indicator set is stored in `iocs.csv`. High-confidence indicators for operational use are intentionally conservative and exclude sandbox baseline domains.

IOC Type	Example / Count	Source	Operational Notes
SHA256	`ffd933ad53f22a0f10cceb4986087258f72dffdd36999b7014c6b37c157ee45f`	Observed	Primary sample identifier
SHA1 / MD5	2	Observed	Useful for legacy tooling correlation
Onion portal	1	Observed (static)	High-value victim-contact indicator
Ransom-note filename	`GET_YOUR_FILES_BACK.txt`	Observed (static)	Strong hunt pivot
Encrypted extension	`.avos2`	Observed (static)	High-value impact pivot
Commands	4 anti-recovery / log-clearing strings	Observed (static)	Detection-oriented rather than attribution-only
Unvalidated domain	`omk.oro`	Observed (static)	Triage only; do not block solely on this

12. MITRE ATT&CK Mapping

Technique	Name	Evidence
T1486	Data Encrypted for Impact	Ransom note, `.avos2`, embedded encryption strings, Crypto++ AES/RSA support
T1490	Inhibit System Recovery	`vssadmin.exe Delete Shadows /All /Quiet`, `wmic shadowcopy delete /nointeractive`, `bcdedit` commands
T1070.001	Clear Windows Event Logs	Embedded PowerShell `Clear-EventLog` command
T1135	Network Share Discovery	`WNetOpenEnumA`, `WNetEnumResourceA`, `REMOTEDISK!` string
T1021.002	SMB/Windows Admin Shares	`WNetAddConnection2A` plus `enablesmb` operator flag
T1222.001	File and Directory Permissions	`SetNamedSecurityInfoW`, ACL-related

	Modification	imports, `SeTakeOwnershipPrivilege` string
--	--------------	--

13.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal	Tuning Notes
Anti-recovery command chain	Windows process creation / command-line logging	Detect ransomware pre-encryption staging	Backup administrators and break-glass maintenance scripts may overlap
`\avos2` file creation or rename	File telemetry / EDR file events	Detect encryption impact at scale	Exclude lab artefacts and known test files
Ransom-note creation	File creation telemetry	Detect post-encryption victim messaging	False positives should be rare
Suspicious SMB enumeration from an end-user host	Process + network share telemetry	Detect pre-impact lateral discovery by ransomware operators	Tune against approved admin tools

13.2 Detection Content

<pre>import "pe" rule AvosLocker_SonicBoom_Win32_Family { meta: description = "Detects the analyzed AvosLocker/SonicBoom Windows sample using raw Crypto++ and ransomware-supporting WinAPI strings" author = "Lost Boys Cyber" date = "2026-06-13" hash = "ffd933ad53f22a0f10cceb4986087258f72dffdd36999b7014c6b37c157ee45f" strings: \$api1 = "WNetOpenEnumA" ascii \$api2 = "RmStartSession" ascii \$api3 = "CryptImportPublicKeyInfo" ascii \$api4 = "CryptEncrypt" ascii \$api5 = "SetNamedSecurityInfo" ascii \$cpp1 = ".?AVEnc@Rijndael@CryptoPP@" ascii \$cpp2 = ".?AVSHA256@CryptoPP@" ascii \$cpp3 = ".?AVAutoSeededRandomPool@CryptoPP@" ascii condition: uint16(0) == 0x5A4D and pe.machine == pe.MACHINE_I386 and 6 of them }</pre>
<pre>title: Potential AvosLocker Anti-Recovery Command Chain id: c0a4f0f0-e1c6-4a5d-b70f-avos-20260613 status: experimental description: Detects commands statically embedded in the analyzed AvosLocker/SonicBoom sample that suppress recovery options and clear evidence. references: - local-analysis:ffd933ad53f22a0f10cceb4986087258f72dffdd36999b7014c6b37c157ee45f logsource: product: windows category: process_creation detection: sel_shadow: CommandLine contains: - 'vssadmin.exe Delete Shadows /All /Quiet' - 'wmic shadowcopy delete /nointeractive' sel_boot: CommandLine contains:</pre>

```

- 'bcdedit /set {default} recoveryenabled No'
- 'bcdedit /set {default} bootstatuspolicy ignoreallfailures'
sel_logs:
  CommandLine|contains:
    - 'Get-EventLog -LogName * | ForEach { Clear-EventLog $_.Log }'
condition: sel_shadow or sel_boot or sel_logs
falsepositives:
  - Rare; investigate backup tooling or destructive admin scripts carefully
level: high

```

13.3 Detection Validation and Blind Spots

The YARA rule is grounded in stable family strings visible in the sample and should be validated against a broader AvosLocker corpus before production deployment. The Sigma analytic is behavior-oriented and should generalize better than a pure hash blacklist, but it may miss operators who recompile the malware without the same embedded commands or who delegate anti-recovery steps to prior intrusion tooling.

14.1 Hunt Hypotheses

- If this sample or a close variant executed in the environment, hosts should show one or more anti-recovery command lines followed by large numbers of file renames or ransom-note creation.
- If operators enabled SMB coverage, compromised systems may show suspicious share enumeration or remote-drive access immediately before encryption impact.

14.2 Hunt Queries

```

// Hunt for AvosLocker-like anti-recovery and log-clearing commands.
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any (
  'vssadmin.exe Delete Shadows /All /Quiet',
  'wmic shadowcopy delete /nointeractive',
  'bcdedit /set {default} recoveryenabled No',
  'bcdedit /set {default} bootstatuspolicy ignoreallfailures',
  'Get-EventLog -LogName * | ForEach { Clear-EventLog $_.Log }'
)
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName
| order by Timestamp desc

// Hunt for AvosLocker impact artefacts: ransom note creation or .avos2 renames.
DeviceFileEvents
| where Timestamp > ago(30d)
| where FileName =~ 'GET_YOUR_FILES_BACK.txt' or FileName endswith '.avos2'
| project Timestamp, DeviceName, ActionType, FolderPath, FileName, InitiatingProcessFileName, SHA1
| order by Timestamp desc

// Hunt for suspicious SMB-oriented pre-impact behavior from user endpoints.
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ('enablesmb', 'WNetAddConnection2A', 'WNetEnumResourceA')
  or InitiatingProcessCommandLine has_any ('enablesmb')
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by Timestamp desc

```

14.3 Triage Guidance for Hunt Hits

High-priority hits are hosts showing anti-recovery commands plus note creation or `.avos2` file activity within a short time window. Benign lookalikes may include administrator use of `vssadmin` or `bcdedit`, but those cases rarely coincide with mass file-write activity, ransom-note filenames, or suspicious share traversal. Escalate immediately to incident response if any host shows both anti-recovery actions and impact artefacts.

15. Triage and Incident Response

Priority actions for any environment where this sample or its artefacts are detected:

- isolate impacted hosts immediately if `.avos2` files or ransom-note creation are present,

- collect EDR process trees, file-write telemetry, and share-access logs before large-scale reboots,
- scope for pre-ransomware operator activity, especially credential theft and remote administration,
- preserve evidence from backup infrastructure, hypervisors, and file servers,
- rotate privileged credentials if there is any sign of lateral movement or administrative share abuse.

This should be treated as a likely intrusion event requiring broader scoping, not merely anti-malware removal of one executable.

16. Validation and Emulation

Validation completed for this task:

- archive extraction and hashing,
- PE triage with `file`, `exiftool`, `rabin2`, and `objdump`,
- decoded-string extraction with FLOSS,
- targeted `radare2` inspection confirming Crypto++ artefacts,
- YARA triage helper execution,
- TRASHcan local detonation with artefact review,
- external corroboration against MITRE, CISA, and Zscaler.

Not completed:

- capa rule output, due repeated 300-second and 600-second timeouts,
- deep decompilation in Ghidra or full cross-reference mapping,
- destructive encryption proof in the sandbox run.

17. Recommendations

Priority	Owner	Action	Rationale
Critical	DFIR / SOC	Hunt immediately for the provided anti-recovery commands, <code>GET_YOUR_FILES_BACK.txt</code> , and <code>.avos2</code> file activity	These are the strongest operational pivots tied directly to the sample
Critical	Infrastructure / Backup	Verify immutability and restore viability of backups before any widespread cleanup	Static strings show explicit backup and recovery suppression intent
High	Detection Engineering	Deploy and tune the Sigma and KQL content in staging, then production	Behavior-based detections provide value even if hashes rotate
High	Threat Hunting	Review SMB share access and suspicious administrative activity around candidate hosts	AvosLocker affiliates commonly operate as part of broader intrusions
Medium	Malware Research	Expand corpus testing for the YARA rule against other AvosLocker samples and benign PE sets	Reduces family-rule false positives before broad deployment

18. References and Refresh Notes

- Local static and dynamic analysis conducted under task workspace `t_1388a9ac` and TRASHcan run `2026-06-13_060903_ffd933ad53f2`.
- CISA, `#StopRansomware: AvosLocker Ransomware (Update)`, advisory AA23-284A.

- MITRE ATT&CK, `AvosLocker`, software entry `S1053`.
- Zscaler ThreatLabz, `A retrospective look at the AvosLocker ransomware group and their associated TTPs`.
- Refresh if later sandbox runs recover a real process tree, dropped notes, or validated network infrastructure beyond the static onion portal.